15.4 Using policy to control access

As ACME expanded its use of policy-based access control, policies shifted from being internal implementation details to becoming the main way the company managed access. Instead of relying on network location, ACME now enforces access by evaluating each request against policies that specify expectations for devices, identity, and application behavior.

Figure 15.4 refines figure 15.2 by illustrating the complete process of an access decision. When a principal tries to perform an action, the request is initially handled by the policy enforcement point at the target resource. The PEP gathers relevant context—such as the authentication session and device posture—and constructs a normalized request that it forwards to the policy engine. Instead of evaluating policies from only one source, the policy engine creates an effective policy set by selecting applicable policies from the foundational, shared operational, and application policy stores. It then evaluates the normalized request against this combined set, yielding a unified authorization decision. This decision is subsequently returned to the PEP, which enforces it at the target resource.